📋 Informe del Proyecto Sprint 1

Nombre:	[Jose Iván Arango Franco]
Fecha:	[9/18/2026]

1. Diagrama de Red (Antes y Después)

📌 *Nota: Dibuja o adjunta tu diagrama en un documento aparte y referencia aquí los elementos clave que identificaste.*

Elemento	ANTES (Vulnerable)	DESPUÉS (Seguro)
Endpoint(s) identificados	* Kali Linux 2024: tiene contraseña para acceder al endpoint pero no tiene ninguna restricción para acceder a la red LAN. *Ubuntu 16.04 LTS Desktop: tiene contraseña para acceder al endpoint pero no tiene ninguna restricción para acceder a la red LAN.	Subred VLAN 1 para usuarios aislada / autenticación de 2 factores para ingresar a cada SO de usuario / Microsegmentación por ACLs con reglas explícitas tipo: Permitir: cualquier host de VLAN 1 → file server (puerto 445) Permitir: cualquier host de VLAN 1 → impresora (puerto 9100/631) Denegar: host a host directo (todo lo demás).
Servidor(es) identificados	* Microsoft SQL Server 2019 Standard (Windows Server 2022): no tiene contraseña para acceder al SO del endpoint ni restricciones para navegar en la red LAN, está altamente expuesto. * Windows Server 2019 Standard: no tiene contraseña para acceder al SO del endpoint ni restricciones para navegar en la red LAN, está altamente expuesto.	Subred VLAN 2 para servidores aislada / autenticación de 2 factores activada para ingresar a cada SO de servidor / Reglas explícitas tipo: Por defecto: servidor a servidor, bloqueado Excepción explícita: solo el puerto específico del servicio que realmente se consume (1433 para SQL, 445 si de verdad necesitan compartir archivos, etc.) Todo tráfico de administración (RDP 3389, SSH 22) restringido a que solo pueda originarse desde una estación de administración específica, no desde cualquier servidor ni desde otra VLAN directamente.
Componentes de red (router, switch, firewall…)	Se asume que tenemos un switch para poder dirigir todos los equipos al router y se tiene un router que es el puerto de acceso a internet. También se tiene un firewall interno para cada equipo.	Se agrega firewall externo con reglas de navegación, filtros, restricciones, permisos de usuarios, perfiles. Se habilita zona DMZ para encontrar brechas de seguridad. Se implementan configuraciones definidas a firewalls internos. Se reemplaza el switch original por un L3 Switch, que centraliza el enrutamiento y las reglas ACL entre VLANs. Se implementa jump host para fortalecer la comunicación entre el

		adm y los servidores mediante session recording.
Flujo del tráfico	La configuración de la red es plana por lo tanto el tráfico en la red LAN puede fluir desde cualquier dispositivo hacia cualquier dispositivo. No hay restricciones web.	Ahora tenemos cinco VLANs separadas: VLAN 1 Usuarios, VLAN 2 Servidores, VLAN 3 invitados. VLAN 4 admin. VLAN 5 IoT Todo el tráfico a través de nuestras VLAN está controlado por reglas y permisos en el nuevo L3 Switch. Firewall externo agregado para restringir y controlar el tráfico web.

2. Resumen Comparativo de Seguridad de Red

Área de Seguridad	ANTES (Vulnerable)	DESPUÉS (Seguro)
Autenticación / Contraseñas	Servidores sin contraseñas	Contraseñas y 2FA para acceder a cada endpoint.
Segmentación de red	Comunicación total entre todos los dispositivos (red plana)	5 segmentaciones aplicadas: VLAN 1 para usuarios en la que se pueden comunicar sólo con ciertos puertos autorizados, VLAN 2 para servidores con estrictas reglas de comunicación entre servidores y con la VLAN 4, VLAN 3 para invitados en la que no se pueden comunicar con ninguna parte de la LAN, solo tienen acceso a internet. VLAN 4 para administradores con acceso a todos los dispositivos de red y a puertos específicos de los servidores. VLAN 5 para otros dispositivos conectados a la red, tales como impresoras o cámaras.
Firewall / Reglas de tráfico	Sin reglas de filtrado; todo el tráfico permitido	VLAN 1: Los dispositivos en VLAN 1 no tienen comunicación directa entre sí (client isolation). El intercambio de archivos e informes se realiza a través de un servidor de archivos centralizado en VLAN 2, con autenticación 2FA y permisos de acceso por usuario/grupo. Se permiten excepciones puntuales (ej. impresoras compartidas) mediante ACLs específicas. VLAN 2: Los servidores en VLAN 2 no tienen comunicación abierta entre sí. Solo se permiten flujos específicos por puerto/servicio según dependencias reales de aplicación (ej. Windows Server → SQL Server

		puerto 1433), documentados mediante ACLs. El acceso administrativo humano (RDP/SSH) requiere 2FA y se realiza exclusivamente a través de un jump host dedicado en VLAN 4, no directamente desde VLAN 1 o 3. VLAN 3 (Invitados): aislamiento total entre dispositivos invitados (client isolation sin excepciones), sin ruta de red hacia VLAN 1, 2 o 4. Acceso mediante portal cautivo con credenciales temporales de expiración automática, con aceptación de términos de uso. Incluye filtrado DNS básico, límite de ancho de banda por dispositivo y expiración de sesión. Cualquier intento de acceso hacia otras VLANs genera alerta. VLAN 4 (Administración): aislada del resto de la red, solo accesible mediante 2FA con token físico y cuentas administrativas dedicadas. Ningún dispositivo de VLAN 1, 2 o 3 puede iniciar conexión hacia VLAN 4. Desde VLAN 4 se administra la infraestructura de red y mediante el jump host, los servidores de VLAN 2 Sin acceso a Internet. Todo acceso queda registrado y genera alerta si se detecta intento de conexión no autorizada desde otras VLAN. VLAN 5 (IoT): aislamiento por defecto de todas las demás VLANs (incluyendo VLAN 1 y VLAN 2); sin acceso saliente a Internet salvo actualizaciones de firmware desde dominios específicos permitidos (allowlist); sin comunicación entre dispositivos IoT entre sí salvo que la función lo requiera explícitamente (ej. cámaras hacia un NVR central). Reglas de puerto específicas por tipo de dispositivo pendientes de definir según el inventario final.
Servicios expuestos	Servicios accesibles sin restricción	La superficie de exposición se redujo mediante segmentación y ACLs; el acceso administrativo humano requiere 2FA. El tráfico servicio-a-servicio se limita por reglas de firewall/ACL a los puertos estrictamente necesarios.

Endurecimiento (Hardening)	Sin controles de endurecimiento	Actualización obligatoria de Ubuntu 16.04 a una versión con soporte activo (22.04/24.04 LTS) Ciclo de parcheo regular documentado para SO y aplicaciones (Logging centralizado (SIEM) de eventos de autenticación, firewall y servidores). Alertas ante intentos de acceso fallidos repetidos o tráfico anómalo entre VLANs. TLS obligatorio para cualquier tráfico de administración. Políticas de contraseñas robustas: longitud mínima, complejidad, expiración, bloqueo tras intentos fallidos, prohibición de reutilización.

3. Mejoras Aplicadas (Soluciones Implementadas)

#	Mejora aplicada	Objetivo de seguridad alcanzado
1	Política de contraseñas robustas y 2FA	Reducir riesgo de accesos no autorizados por técnicas de suplantación, phishing y otras.
2	Configuración de VLANs con micro segmentación.	Limitar el movimiento lateral dentro de la red, reduciendo la posibilidad de un posible ataque.
3	Nuevo firewall externo con reglas 'Denegar por defecto' aplicando ciertas excepciones	Reducir superficie de ataque mientras se permite la comunicación estrictamente necesaria entre diferentes partes de la red.
4	Nuevas reglas y configuraciones aplicadas a los firewalls internos.	Contar con una doble capa de seguridad entre los dispositivos y el L3 Switch, de manera que si se abre una brecha por un lado, se puede contener por el otro.
5	Ciclo de parcheo regular documentado	Asegurarse de no quedar expuestos eventualmente por tener software desactualizado.
6	Implementación de Jump Host	Permite tener un historial completo de las acciones realizadas sobre los servidores y los dispositivos de red, el cual no ofrece el L3 Switch
7	Implementación de DMZ	Exponer un honeypot para obtener información de los movimientos de posibles atacantes.

4. Análisis Técnico de las Debilidades Descubiertas

Debilidad	Descripción técnica	Riesgo / Impacto

Falta de autenticación fuerte	Ausencia de contraseñas en los sistemas operativos de Microsoft SQL Server 2019 y Windows Server 2019 Standard; sin política de complejidad, expiración ni bloqueo por intentos fallidos en ningún endpoint o servidor.	Permite ataques de fuerza bruta y acceso no autorizado inmediato sin credenciales; facilita el movimiento lateral una vez comprometido un solo equipo, ya que no hay fricción adicional para escalar a otros sistemas.
Ausencia de microsegmentación (red plana)	Topología de red sin VLANs ni ACLs: todos los dispositivos (endpoints de usuario y servidores críticos) comparten la misma raíz de dominio y pueden iniciar comunicación directa entre sí sin restricción de puerto, protocolo ni origen	Un atacante que compromete cualquier endpoint (ej. un dispositivo de usuario) obtiene visibilidad y alcance de red directo hacia los servidores de base de datos y aplicaciones sin ningún control intermedio que lo detecte o bloquee
Firewall perimetral ausente o mal configurado	No existe un firewall externo que controle el tráfico entre la LAN e Internet; los únicos firewalls presentes son de host, sin reglas de filtrado activas ni políticas de "default deny"	Aumenta la superficie de ataque expuesta a Internet; servicios internos (SQL Server, Windows Server) podrían ser alcanzables externamente sin ninguna capa de inspección o bloqueo de tráfico malicioso entrante
Software con fin de soporte (End-of-Life)	El endpoint Ubuntu 16.04 LTS Desktop utiliza una versión de sistema operativo cuyo soporte estándar finalizó en abril de 2021, sin recepción de parches de seguridad desde esa fecha	Vulnerabilidades conocidas y públicamente documentadas (CVEs) permanecen sin corregir de forma indefinida; ningún control de segmentación de red mitiga una explotación local o mediante ejecución de código en el propio SO
Ausencia de monitoreo y registro centralizado (logging)	No existe recolección centralizada de logs de autenticación, tráfico de firewall ni actividad de servidores; no hay mecanismo de alertas ante eventos anómalos	Un compromiso puede pasar completamente desapercibido; sin trazabilidad no es posible reconstruir el alcance de un incidente ni determinar tiempos de exposición (dwell time) del atacante
Superficie de exposición de servicios sin justificación	Los servidores no restringen los servicios/puertos activos a los estrictamente necesarios (ej. sin cierre de puertos administrativos como RDP/SSH cuando no se requieren desde cualquier origen)	Cada puerto o servicio innecesariamente activo constituye un vector de ataque adicional; incrementa la probabilidad de explotación de vulnerabilidades no relacionadas con la función principal del servidor
Ausencia de control de acceso administrativo diferenciado	No existe separación entre el acceso administrativo (gestión de infraestructura y servidores) y el acceso de usuario estándar; cualquier equipo con conectividad de red puede intentar autenticarse directamente contra los servidores críticos	Compromete el principio de mínimo privilegio; facilita que un atacante con acceso a cualquier segmento de red intente autenticación directa contra activos de alto valor, sin necesidad de pasar por un punto de control intermedio auditable

5. Resumen Ejecutivo (Informe tipo SOC)

Pregunta guía	Tu respuesta (reemplaza el texto entre corchetes)
¿Qué observaste?	Al analizar la red, inicialmente encontré una topología completamente plana: un solo switch conectando todos los dispositivos sin ningún tipo de segmentación. Identifiqué dos endpoints (Kali Linux 2024 y Ubuntu 16.04 LTS Desktop) con contraseña a nivel de sistema operativo pero sin ninguna restricción de red, y dos servidores críticos (Microsoft SQL Server 2019 y Windows Server 2019) que ni siquiera tenían contraseña configurada. No existía firewall perimetral, solo firewalls internos sin reglas activas de filtrado.
¿Qué riesgo existía?	El riesgo principal era el movimiento lateral sin fricción: al ser una red plana, cualquier dispositivo comprometido —incluso el más simple, como un endpoint de usuario— tenía visibilidad y alcance directo hacia los servidores más críticos de la organización. Sumado a la falta de contraseñas en los servidores, esto significaba que un atacante no necesitaba explotar ninguna vulnerabilidad sofisticada para llegar a los activos de mayor valor; bastaba con estar dentro de la red.
¿Qué acciones se tomaron?	Rediseñé la red aplicando microsegmentación en cinco VLANs (usuarios, servidores, invitados, administración e IoT), cada una con reglas de tráfico explícitas basadas en el principio de "denegar por defecto, permitir por excepción". Implementé un L3 Switch para controlar el tráfico entre VLANs mediante ACLs, mantuve los firewalls internos como una segunda capa de defensa a nivel de host, y agregué un firewall externo para controlar el tráfico hacia Internet. Para el acceso administrativo, incorporé un jump host dentro de la VLAN de administración, que permite mantener un registro de sesión (session recording) de todo lo que ocurre entre los administradores y los servidores, algo que las reglas del L3 Switch por sí solas no pueden ofrecer. También habilité una DMZ con un honeypot para poder observar el comportamiento de posibles atacantes, y establecí políticas de autenticación fuerte (contraseñas robustas + 2FA) en todos los endpoints y servidores.
¿Cuál fue el resultado?	La red pasó de un modelo plano y sin control, a una arquitectura de defensa en profundidad con múltiples capas independientes: segmentación de red, control de acceso administrativo diferenciado, autenticación reforzada y visibilidad mediante logging centralizado. Ya no existe una ruta directa entre un endpoint de usuario comprometido y un servidor crítico; cualquier intento de ese tipo tendría que cruzar varios controles (ACLs del L3 Switch, firewall de host, autenticación 2FA) y quedaría registrado.
Recomendaciones futuras	Como próximos pasos, recomendaría implementar un sistema IDS/IPS para detección activa de amenazas (más allá del honeypot pasivo de la DMZ), definir con mayor detalle las reglas específicas de la VLAN de IoT según el inventario real de dispositivos, establecer un plan formal de respuesta a incidentes, y programar auditorías periódicas de las reglas ACL para evitar que con el tiempo se acumulen excepciones innecesarias.

🗒️ *Recuerda: el trabajo de seguridad no busca la perfección, sino entender qué existe, qué podría salir mal, qué importa más y qué se puede mejorar.*